

Module 6: Cybersecurity Fundamentals

Day 6 - Incident
Response Reporting



Module 6 — Course Overview

Day	Date	Topic
✓ Day 1	Mar 18	Threat Intelligence & Frameworks
✓ Day 2	Mar 25	URL Analysis & Vulnerability Fundamentals
✓ Day 3	Apr 15	Phishing & Email Security
✓ Day 4	Apr 22	Password Security & Network Traffic Analysis
✓ Day 5	Apr 29	Malware Analysis & SIEM
▶ Day 6	May 20	Incident Response Reporting
Day 7	May 27	Capstone — Simulated Incident Investigation

What We Learned So Far — Days 1–5

- Day 1 — Threat Intelligence: Kill Chain, ATT&CK, OSINT, TI lifecycle
- Day 2 — URL & Vulnerabilities: scanning, CVEs, exploitation
- Day 3 — Phishing: social engineering, email auth, MGM case study
- Day 4 — Password & Network: Hashcat, PtH, Kerberoasting, Wireshark, C2
- Day 5 — Malware & SIEM:
 - Static/dynamic malware analysis, Volatility memory forensics
 - SIEM architecture, Sysmon, Windows Event IDs, SOAR, Sigma rules

Why Reports Matter

- **Reports communicate:**
 - What happened (incidents)
 - What we found (assessments)
 - What's the risk (vulnerabilities)
 - What to do (recommendations)
- **Your work is invisible without documentation**

NIST Incident Response Lifecycle

- Phase 1 — Preparation: policies, tools, training, runbooks
- Phase 2 — Detection & Analysis: identify, triage, scope the incident
- Phase 3 — Containment, Eradication & Recovery: isolate (short-term) + patch/harden (long-term); remove malware, close access vectors, reset credentials; restore systems, monitor for reinfection, validate
- Phase 4 — Post-Incident Activity: lessons learned, update runbooks, report findings
- Reference: NIST SP 800-61r2 (4 phases). SANS PICERL splits Containment / Eradication / Recovery into 3.

Containment Strategies

- Short-term: isolate host (network block/VLAN), disable account, block IOC at firewall
- Long-term: patch vulnerability, deploy compensating controls, improve monitoring
- Decision factors: business impact vs. risk of leaving attacker in environment
- Legal: preserve evidence BEFORE wiping — image drives, export logs first
- Communication: who needs to know? (CISO, legal, HR, affected business units)
- Document every containment action with timestamp

CYBERLABS Post-Incident Activity — Lessons Learned

- Hold within 2 weeks while memories are fresh
- Key questions: What happened? What worked? What failed? What to improve?
- Output: updated runbooks, new detection rules, training gaps identified
- Report recipients: CISO, board (summarized), team (full), regulators if required
- Metrics to track: MTTD (Mean Time to Detect), MTTR (Mean Time to Respond)
- No blame culture — focus on process improvement, not individual fault

Report Types

- **Common security reports:**
 - **Incident Report:** Document security events
 - **Vulnerability Report:** Assessment findings
 - **Penetration Test Report:** Authorized testing results
 - **Threat Intelligence Report:** Threat analysis
 - **Executive Summary:** High-level overview
 - **Technical Report:** Detailed findings
- **Different audiences need different reports**

Know Your Audience

Audience	Focus	Language
Executives	Risk, impact, cost	Business terms
Management	Resources, timeline	Mixed
Technical	Details, reproduction	Technical terms

Incident Report Structure

- **Incident report sections:**
 - 1.Executive Summary** - Key facts, impact, status
 - 2.Incident Timeline** - Chronological events
 - 3.Technical Details** - What happened technically
 - 4.Indicators of Compromise (IOCs)** - Type, value (defanged), confidence
 - 5.Containment & Eradication** - Actions taken with reasoning
 - 6.Recovery** - Restoration steps, verification
 - 7.Lessons Learned & Recommendations** - Gaps + actionable fixes

Executive Summary Writing

- **Executive summary must answer:**
 - What happened?
 - What was the impact?
 - What did we do?
 - What should leadership know?
- **Keep it:** One page or less, jargon-free, action-oriented
- **Lead with impact, not technical details**

Timeline Documentation

- **Timeline format:**

YYYY-MM-DD HH:MM (Timezone)

```
2026-04-27 09:23 UTC - Phishing email delivered to
user@company.com
2026-04-27 09:45 UTC - User clicked malicious link
2026-04-27 09:46 UTC - Malware executed, beacon
established
2026-04-27 10:15 UTC - Lateral movement to server01
2026-04-27 14:30 UTC - Alert triggered by SOC
2026-04-27 14:45 UTC - Containment initiated
```

CVSS in Reports

- Include CVSS for vulnerabilities:
- Standardized scoring enables prioritization (use CVSS 4.0 — released Nov 2023; 3.1 still widely seen)

Vulnerability: SQL Injection in Login Form

CVSS: 9.8 (Critical)

Vector (4.0):

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Interpretation: Network accessible, no authentication required,
complete system compromise possible.

Technical Detail Balance

- **Include enough detail to:**
 - Reproduce the finding
 - Understand the impact
 - Implement the fix
 - Learn from the incident
- **Avoid:**
 - Excessive screenshots without context
 - Raw log dumps without analysis
 - Jargon without explanation

Recommendations

- **Effective recommendations are:**
 - **Specific:** Clear action to take
 - **Measurable:** Can verify completion
 - **Achievable:** Realistic to implement
 - **Relevant:** Addresses the actual issue
 - **Time-bound:** Include priority/timeline
- **Bad:** "Improve security"
- **Good:** "Implement MFA for VPN access by Q2"

Including Evidence

- **Supporting evidence:**
 - Screenshots (annotated)
 - Log excerpts (highlighted)
 - Network captures (relevant portions)
 - File hashes
 - IOCs (defanged)
- **Evidence handling:**
 - Preserve originals
 - Document chain of custody
 - Defang malicious indicators

Regulatory Notification Requirements

- Most breaches trigger legal notification deadlines:
 - GDPR (EU personal data): 72 hours to supervisory authority
 - SEC (US public companies): 4 business days for material incidents
 - HIPAA (US healthcare): 60 days for breaches affecting 500+ individuals
 - NIS2 (EU critical infrastructure): 24h early warning, 72h full notification
 - PCI-DSS: notify card brands and acquirer per card-brand timeline (typically within 24h)
- IR plan must specify: who decides it's reportable, who notifies, template ready
- Involve legal counsel early — late notification = additional fines

Chain of Custody — Evidence Handling

- Every piece of evidence must have an unbroken chain of custody
- Required documentation per item:
 - Who collected it | When and where | Current storage location
 - Who has accessed it | Any transformations applied
- Process: Identify → Collect → Hash → Document → Secure → Transfer
- Never analyze originals — work on forensic copies only
- Hash verification: sha256sum before and after any transfer
- Why it matters: breaks in chain = evidence inadmissible in court

Common Report Mistakes

- **Avoid these mistakes:**
 - **X** Burying the lead (key finding on page 10)
 - **X** Assuming reader knowledge
 - **X** Missing recommendations
 - **X** Lack of prioritization
 - **X** No executive summary
 - **X** Undefanged malicious indicators
 - **X** Jargon without explanation
 - **X** Missing evidence for claims

Report Review Process

- **Before publishing:**
 - [] Spell check and grammar review
 - [] Technical accuracy verification
 - [] Sensitive information check
 - [] Peer review
 - [] Management approval (if required)
 - [] Defanged all IOCs
 - [] Executive summary standalone test

Day 6 Summary — Incident Response Reporting

- NIST IR lifecycle (4 phases): Preparation → Detection & Analysis → Containment/Eradication/Recovery → Post-Incident
- Containment: isolate first, preserve evidence BEFORE wiping — image drives, export logs
- Reports have audiences: executives (business impact, 1 page) vs technical teams (full detail)
- Report structure (7 sections): exec summary → timeline → technical → IOCs → containment/eradication → recovery → lessons learned
- Chain of custody: every item hashed and documented — breaks = inadmissible in court
- Regulatory deadlines: GDPR 72h | SEC 4 days | HIPAA 60 days | NIS2 72h
- Post-incident: update runbooks, new detection rules, MTTD/MTTR metrics, no-blame culture

Module 6 Summary

- **Module 6 covered:**
 - Threat landscape and attack frameworks
 - OSINT and reconnaissance
 - Vulnerability scanning and CVEs
 - Phishing and email security
 - Password attacks and defenses
 - Network traffic and C2 analysis
 - Malware and memory analysis
 - SIEM architecture
 - Professional report writing

Preparing for Practical Labs

- **Ready for labs:**
 - [] VMs configured and snapshotted
 - [] IR report template ready (Word/Notepad)
 - [] Analysis tools available
 - [] Sample files ready
 - [] Isolated network prepared
- **Labs cover:**
 - Lab 1 — IR Report Writing (NIST SP 800-61 / Sentinel)
 - Lab 2 — Evidence Collection (volatile data, MDE Live Response)
 - Lab 3 — Timeline Building (Kill Chain + MITRE ATT&CK mapping)

© CyberLabs Technologies

Thank You

